Victor Caldas dos Santos - Fundamentos de Hacking Ético e Metodologias de Pentest

Termo de Engajamento

- **Contratante:** DiscadaNet Telecomunicações
- **Contratado:** Equipe Pentest
- **Tipo de consulta:** API Web (Interface via Console / HTML)

1. Objetivo

O objetivo deste teste é avaliar a segurança e a resiliência da API de Viabilidade de Rede da DiscadaNet contra tentativas de manipulação de requisições, injeções de códigos e vazamento de dados estruturados através do terminal de consulta, mitigando riscos de fraudes no sistema de vendas.

2. Escopo e Exclusões

Sendo a DiscadaNet uma companhia focada no setor de telecomunicações, as atividades serão focadas na interface web que se comunica diretamente com a API.

- Ativos Incluídos:
    - Endpoint da API de Viabilidade: https://api-viabilidade.discadanet.com.br/console/v1
    - Validação dos parâmetros de entrada HTTP (POST e GET) enviados via console.
    - Testes para identificar falhas de Command Injection, quebra de autenticação e injeção de tags na renderização do HTML.
- Ativos Excluídos:
    - Infraestrutura interna, servidores de banco de dados isolados e roteadores de borda.
    - Sistemas corporativos de faturamento e portais principais de clientes.
    - Técnicas de engenharia social contra colaboradores ou ataques de negação de serviço (DDoS).

3. Regras do Teste

- Janela de Execução: Os testes serão realizados estritamente entre 23:00h e 05:00h, visando diminuir qualquer impacto nas consultas legítimas de viabilidade de rede da operadora.
- Técnicas Permitidas: Mapeamento de rotas expostas, testes de bypass em parâmetros da API e injeção de cargas úteis (payloads) controladas.
- Critérios de Parada: As atividades serão interrompidas imediatamente se houver lentidão excessiva no servidor (Erros HTTP 5XX) ou travamento do interpretador do console de vendas.
- Segurança de Dados: É proibida a inserção de códigos da empresa, credenciais ou informações reais de clientes em ferramentas de inteligência artificial de uso público.

4. Evidências e Comunicação

- Coleta de prints do console, logs de requisições modificadas (Raw HTTP) e respostas do servidor que comprovem a existência da falha.
- Mascaramento de dados confidenciais ou informações de clientes que venham a ser expostas durante os testes.
- Comunicação imediata (em até 2 horas) com o time de TI da DiscadaNet caso seja encontrada alguma vulnerabilidade crítica de execução de código (RCE).

5. Relatório Final

O relatório final apresentará as vulnerabilidades encontradas de forma organizada por nível de criticidade (Baixo, Médio, Alto, Crítico). O documento conterá o sumário executivo com os riscos para o negócio, a prova de conceito (PoC) técnica das falhas identificadas e as recomendações práticas de correção para o time de desenvolvimento.

6. Autorização

O cliente autoriza a execução das atividades descritas neste documento exclusivamente dentro da janela e do escopo acordados. A equipe de testes compromete-se a respeitar os limites estabelecidos e relatar imediatamente qualquer impacto operacional ou achado crítico.

_____

Assinatura - DiscadaNet Telecomunicações S.A.

Data: __/__/2026

_____

Assinatura - Equipe Pentest

Data: __/__/2026